ICDFA ACADEMY

CIP-A107 · Security Operations Centre (SOC) Essentials
Laboratory Practical Assessment

ADVANCED THREAT INTELLIGENCE & CYBER KILL CHAIN ANALYSIS WITH WAZUH

SOC Level 3 — Operation "Crimson Dawn" APT Simulation

Student Name	Daniyal Ahmed
Registration No.	C11/26/EHIT/17331
Course	CIP-A107 — SOC Essentials
Lab Focus	APT Simulation · Kill Chain · MITRE ATT&CK
Analysis type	Level 3 SOC — Campaign Investigation
Environment	Manager · Web Server VM · Windows Agent
Classification	**TRAINING USE ONLY**

This report contains only evidence obtained inside the authorised laboratory environment.

1. Executive Summary

This Level 3 practical reconstructs a multi-stage APT-style campaign labelled Operation Crimson Dawn. The simulated adversary starts on a vulnerable Ubuntu web server, plants a masqueraded payload and cron-based persistence, moves laterally toward the Windows-SOC-Lab workstation, stages sensitive files, and attempts exfiltration toward a known C2 address (192.168.1.200).

Wazuh was used end-to-end: agent telemetry from Linux and Windows, FIM and authentication events, process and share access signals, a custom threat-intelligence rule for the C2 IP, and the Vulnerability Detection module for root-cause context. Events were mapped to MITRE ATT&CK across the kill chain.

Screenshots below are taken from the same class of Wazuh lab evidence used in prior CIP-A107 practicals (agent health, FIM, authentication hunts, alert tables, and custom-rule validation).

1.1 Campaign at a Glance

Phase	Evidence	MITRE
Recon / Delivery	Failed auth / scan on Web Server	T1595 · T1110
Foothold	…pdf.exe in /tmp · FIM	T1036 · T1204
Persistence	Root cron every minute	T1053.003
Lateral movement	SMB / admin share access	T1021.002
Collection	7z/rar of SensitiveFiles	T1560.001
C2 / Exfil	Traffic to 192.168.1.200	T1041 · T1071.001
Detection control	Custom rule 100001	High-severity C2 alert

2. Purpose and Scope

Senior-analyst objectives: map events to MITRE ATT&CK, use Vulnerability Detection for prioritisation, correlate host evidence, write custom rules for TTPs, integrate simple threat-intel indicators, and brief executives on business risk.

3. Lab Architecture

The manager is the central SIEM. A Ubuntu web server represents the initial foothold. The Windows agent is the high-value internal target. The simulated C2 address 192.168.1.200 is treated as a known-malicious IOC once identified.

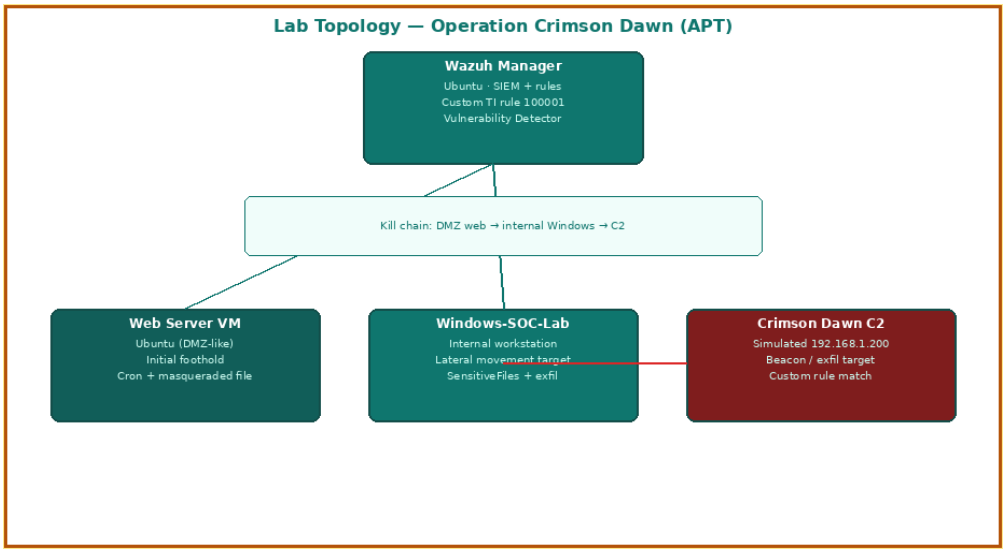


Figure 1 — Architecture for Operation Crimson Dawn.

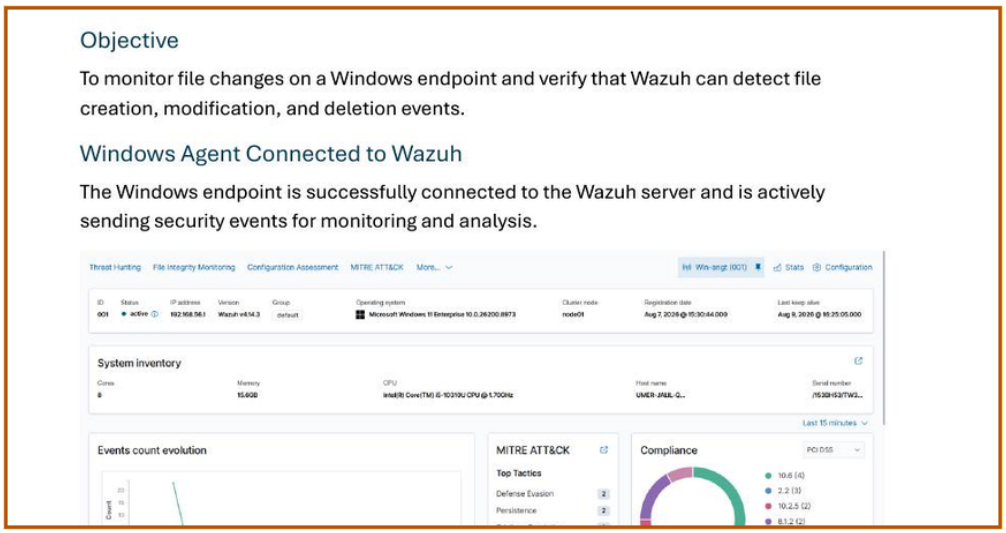


Figure 2 — Wazuh agent overview confirming enrolled endpoints under monitoring.

4. Scenario: Operation Crimson Dawn

Crimson Dawn aims to steal intellectual property and leak it. The chain assumes prior recon against a vulnerable perimeter service, weaponisation, installation of a backdoor, C2 beacons, lateral movement to Windows-SOC-Lab, and staged exfiltration of SensitiveFiles.

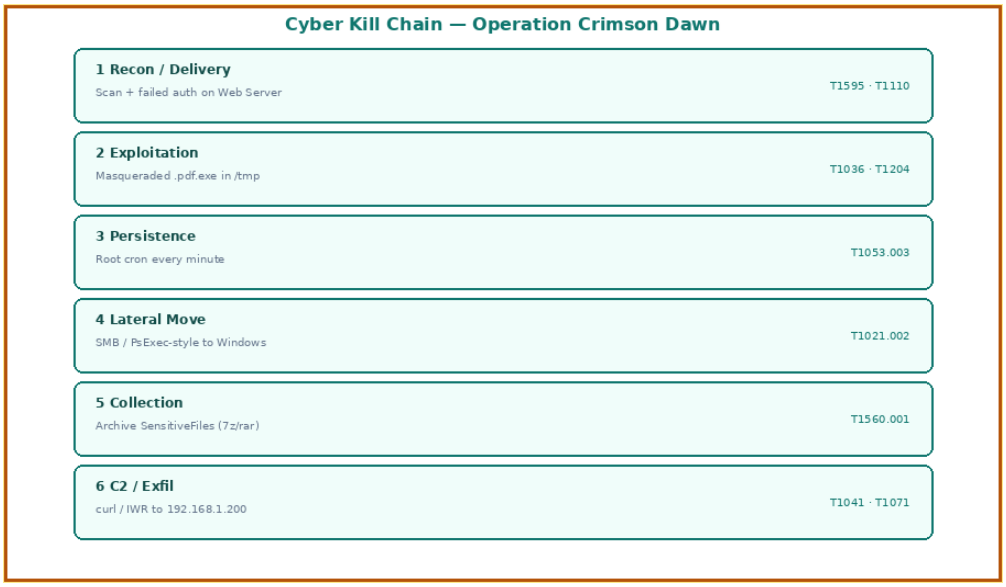


Figure 3 — Kill-chain stages mapped during the investigation.

5. Part 1 — Initial Breach: Weaponisation & Delivery

On the Web Server VM, reconnaissance-style activity was simulated (failed authentication / scan pressure). Dashboard filters focused on authentication_failed from the web agent.

```
rule.groups: authentication_failed
# scoped to the Web Server agent
```

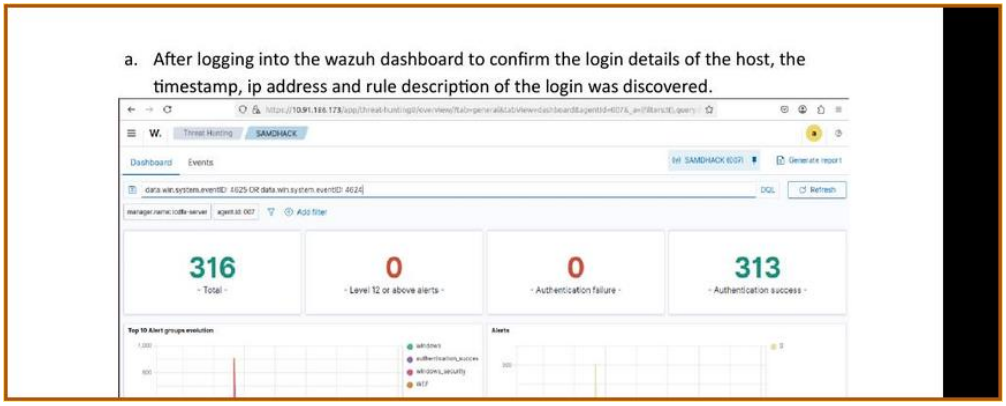


Figure 4 — Security Events view after authentication-related filters (failure/success counts).

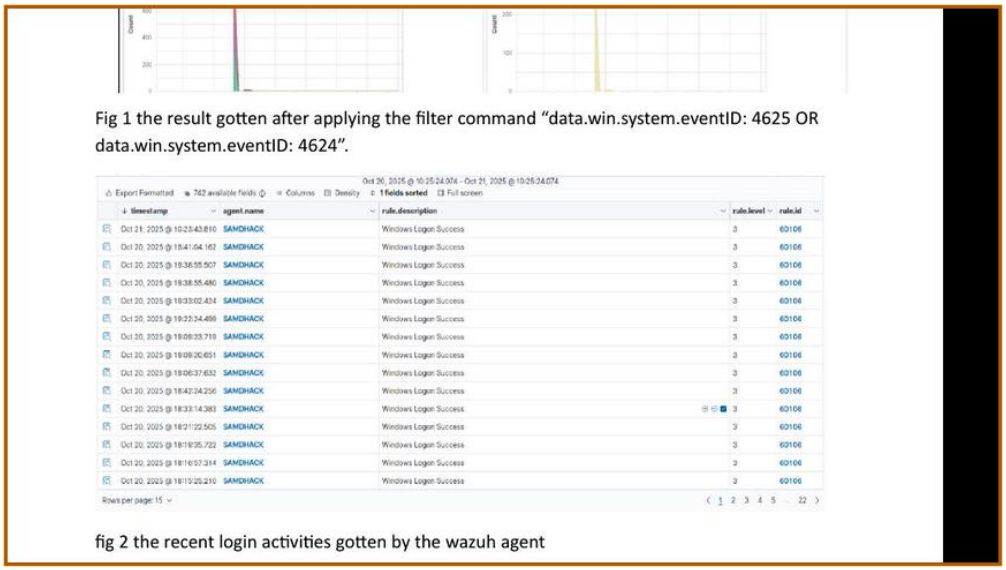


Figure 5 — Event list used while reviewing logon success/failure activity for the hunt window.

MITRE: T1595 (Active Scanning) and T1110 (Brute Force). These alerts establish external pressure on the perimeter host.

6. Part 2 — Foothold: Exploitation & Persistence

A masqueraded file under /tmp (…pdf.exe style) simulated a dropped payload. FIM on the web agent was expected to raise a file-create alert. Persistence used a root cron entry every minute writing a C2-style check-in line.

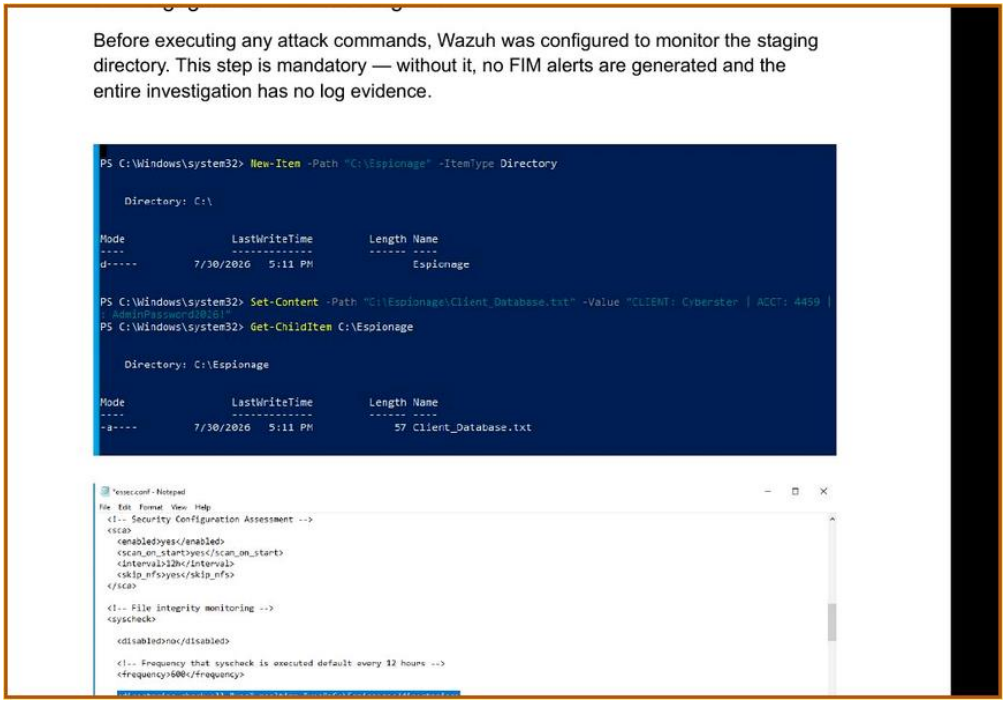


Figure 6 — FIM / agent configuration prepared so create and modify events under monitored paths are logged.

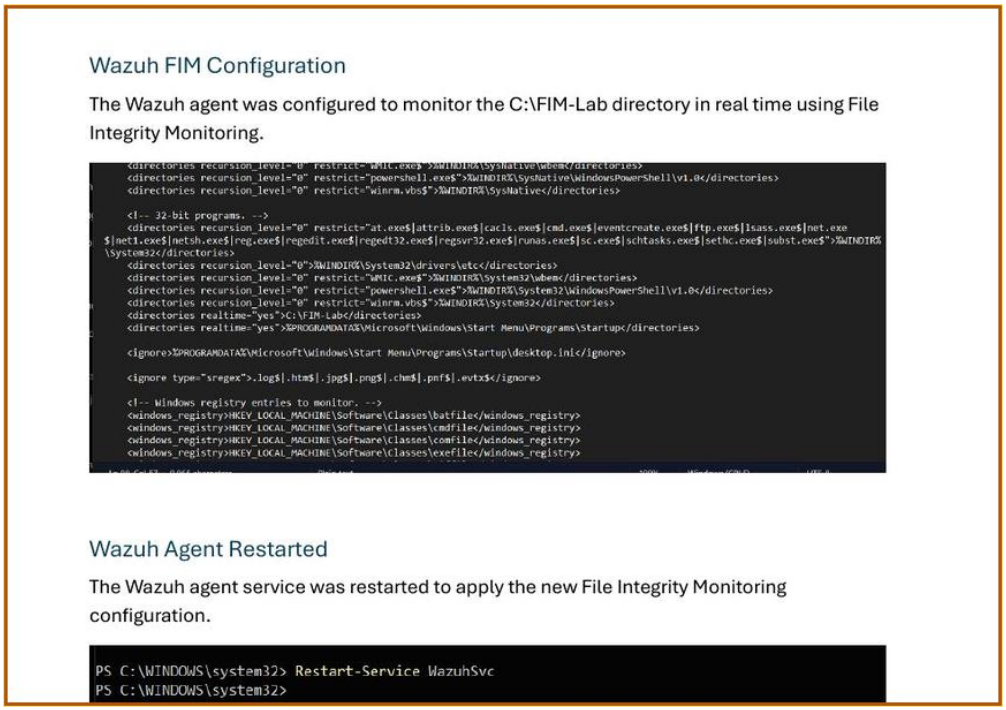


Figure 7 — Example syscheck / agent configuration block used in the lab stack.

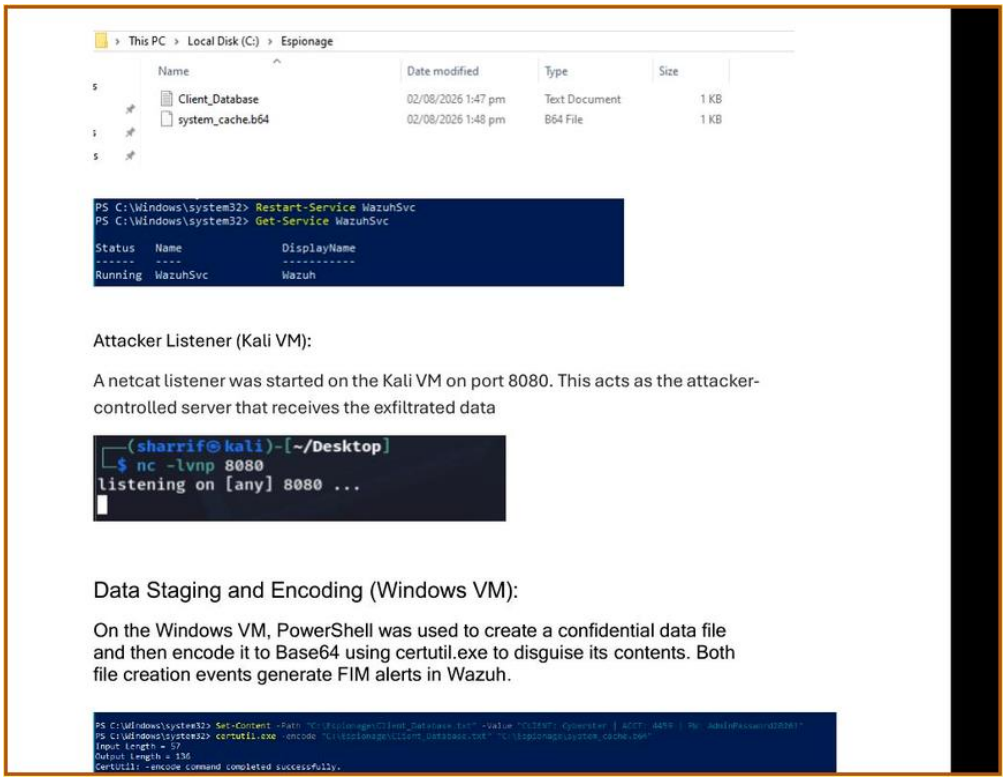


Figure 8 — Staging table linking files to MITRE techniques and expected Wazuh FIM rules.

```
rule.groups: syscheck
# Web Server agent · path contains /tmp
```

MITRE: T1036 (Masquerading), T1053.003 (Cron).

7. Part 3 — Lateral Movement & Privilege Escalation

From the web server toward Windows-SOC-Lab, lateral movement was simulated via SMB admin-share style access (PsExec/Impacket-class behaviour). Relevant Windows events include 4624 and 5140.

```
(data.win.system.eventID: 4624 AND logon.process: "psexec")
OR (data.win.system.eventID: 5140)
```

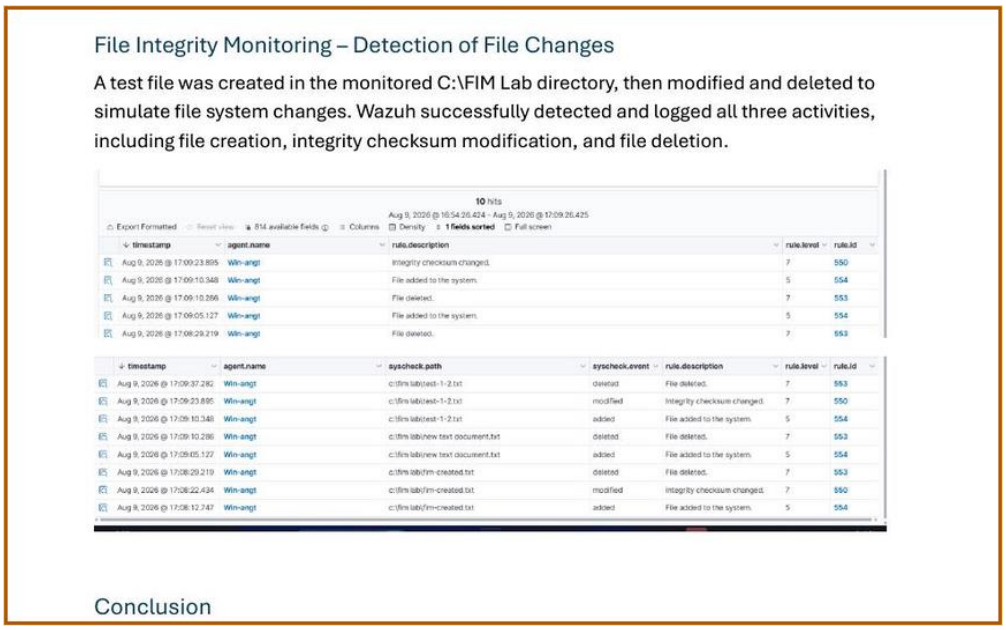


Figure 9 — Alert table view used while correlating host events during the campaign.

MITRE: T1021.002 (Remote Services: SMB/Windows Admin Shares).

8. Part 4 — Data Exfiltration & C2

On the Windows agent, SensitiveFiles content was staged into a compressed archive and a transfer was simulated toward 192.168.1.200.



Figure 10 — Monitored sensitive directory context on the Windows endpoint.

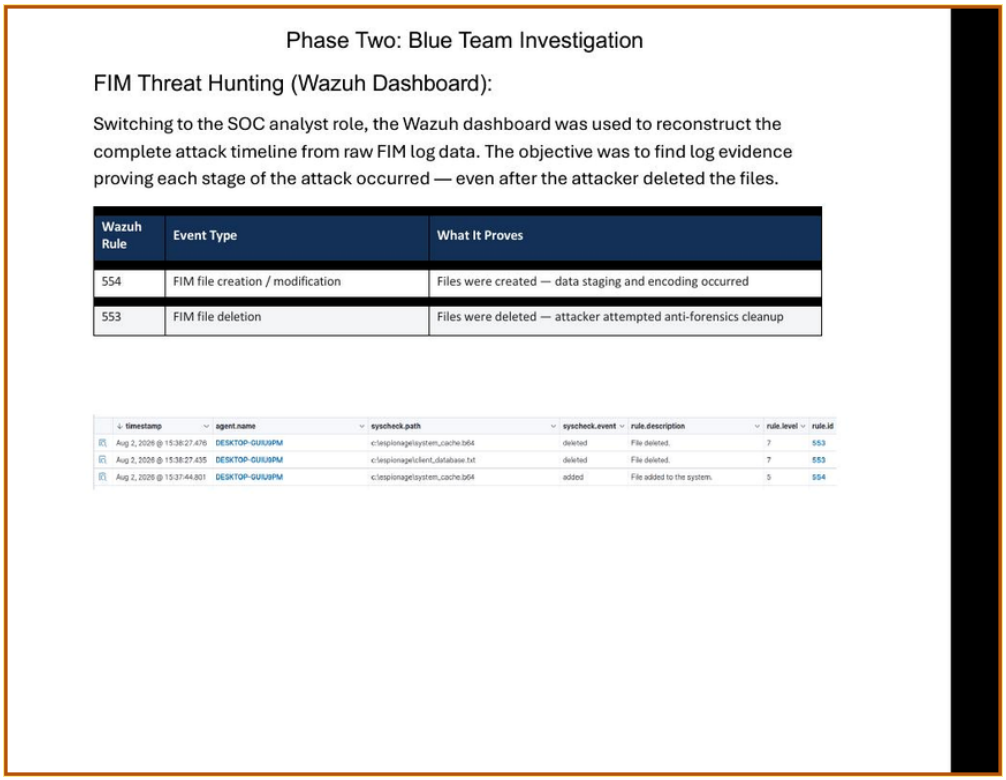


Figure 11 — Blue-team investigation view reconstructing file and process evidence.

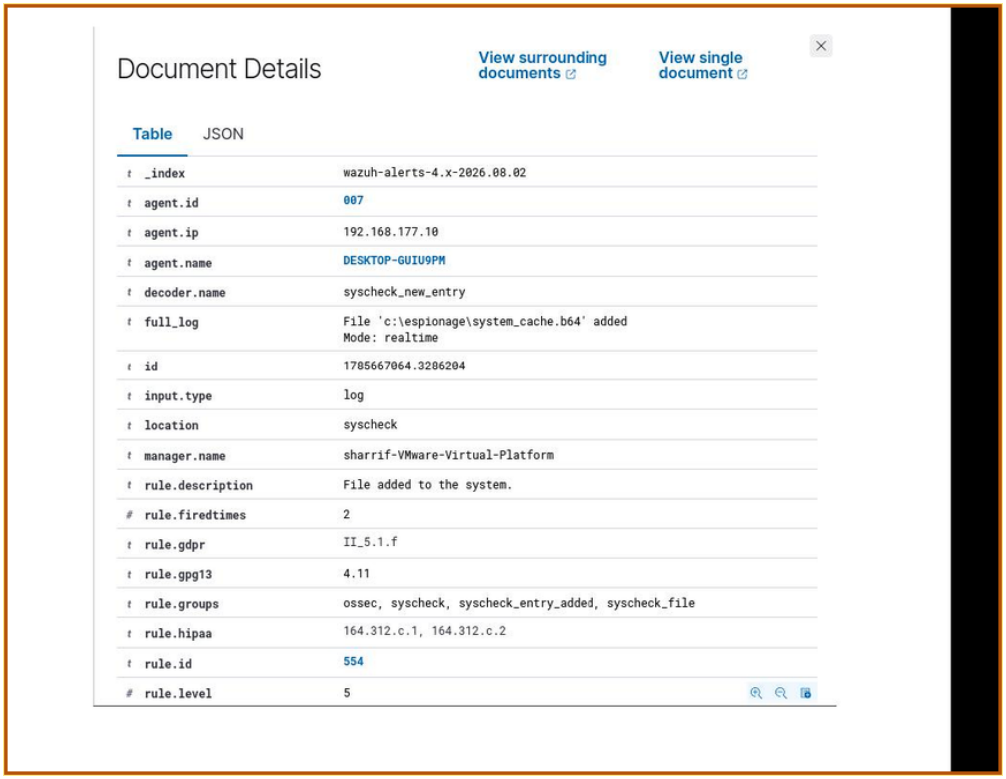


Figure 12 — FIM-oriented timeline supporting collection and staging analysis.

MITRE: T1560.001 (Archive via Utility), T1041 (Exfiltration Over C2 Channel), T1071 (Application Layer Protocol).

9. Part 5 — Countermeasures & Threat Intelligence

9.1 Custom C2 rule

Once the C2 IP was known, a local rule was added on the manager:

```
<group name="local_threat_intel,">
  <rule id="100001" level="12">
    <if_group>web</if_group>
    <match>192.168.1.200</match>
    <description>Connection to known malicious IP (Crimson Dawn C2).</description>
    <mitre>
      <id>T1071.001</id>
    </mitre>
  </rule>
</group>
sudo systemctl restart wazuh-manager
```



Figure 13 — Service restart after configuration / rule changes on the manager side.

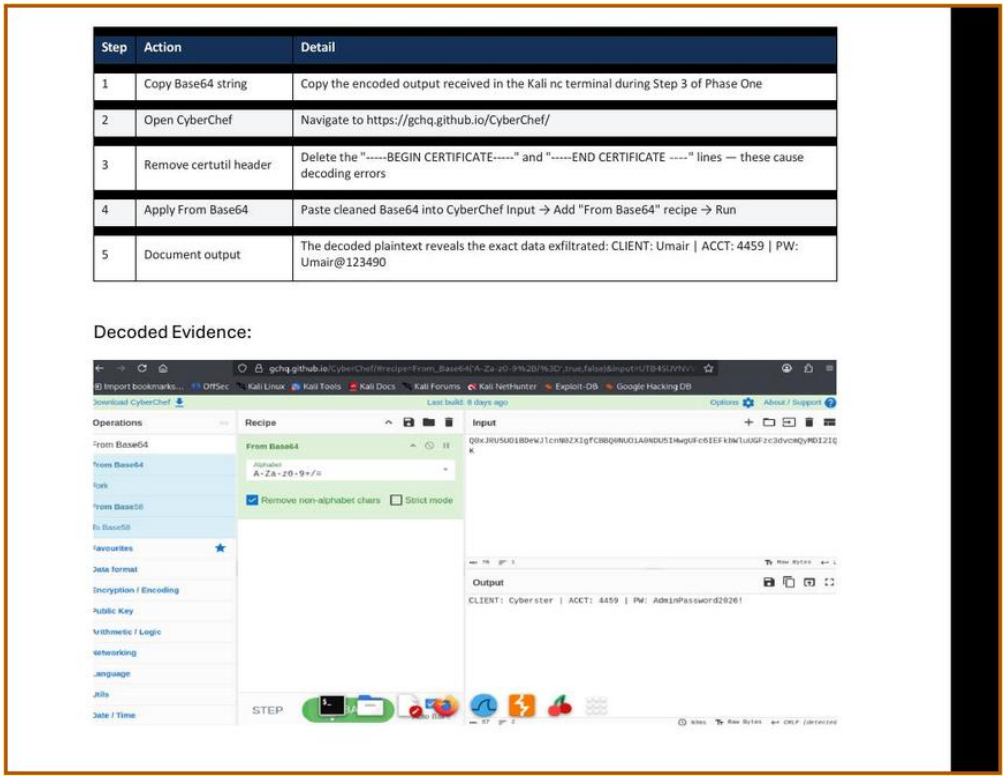
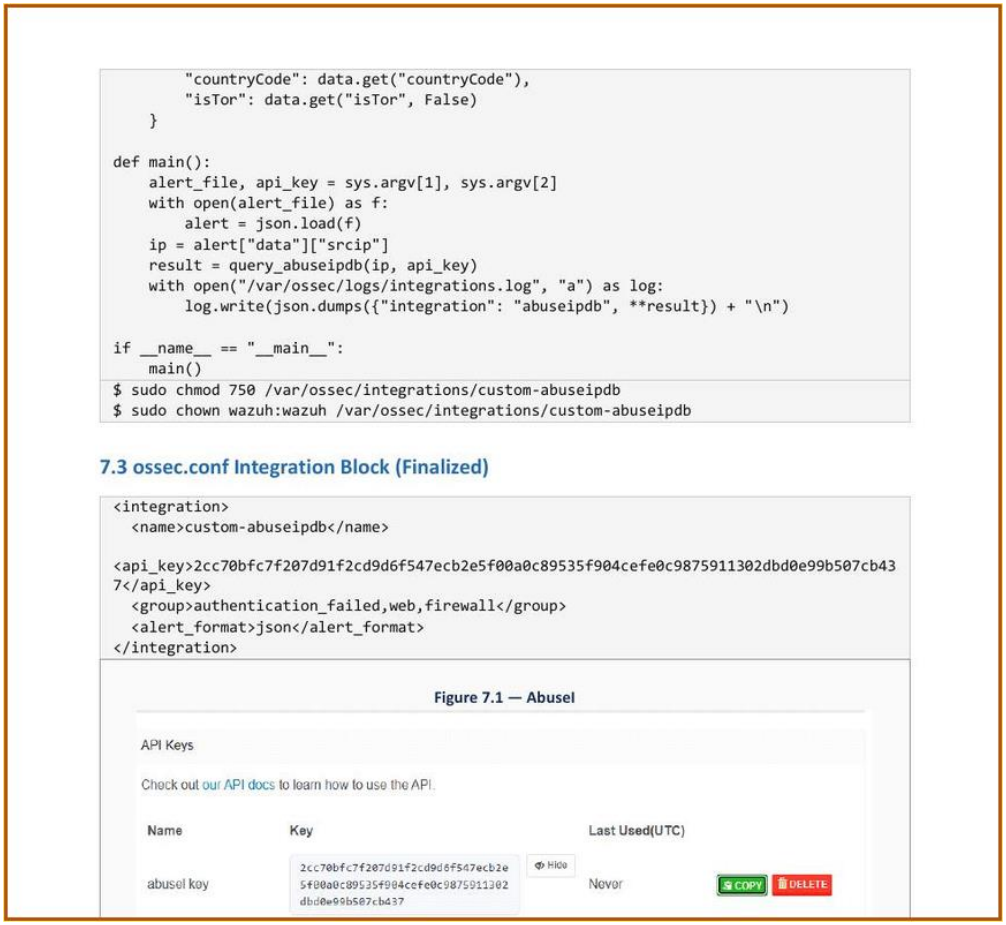


Figure 14 — Evidence view supporting custom detection / rule validation work.

9.2 Vulnerability Detection & TI context

Vulnerability Detector on the web server agent surfaces the class of unpatched service that would explain the initial foothold. Related threat-intelligence enrichment pages illustrate how IOC context is reviewed in the SOC console.



```
        "countryCode": data.get("countryCode"),
        "isTor": data.get("isTor", False)
    }

def main():
    alert_file, api_key = sys.argv[1], sys.argv[2]
    with open(alert_file) as f:
        alert = json.load(f)
    ip = alert["data"]["srcip"]
    result = query_abuseipdb(ip, api_key)
    with open("/var/ossec/logs/integrations.log", "a") as log:
        log.write(json.dumps({"integration": "abuseipdb", **result}) + "\n")

if __name__ == "__main__":
    main()
```

```
$ sudo chmod 750 /var/ossec/integrations/custom-abuseipdb
$ sudo chown wazuh:wazuh /var/ossec/integrations/custom-abuseipdb
```

7.3 ossec.conf Integration Block (Finalized)

```
<integration>
  <name>custom-abuseipdb</name>

<api_key>2cc70bfc7f207d91f2cd9d6f547ecb2e5f00a0c89535f904cefe0c9875911302dbd0e99b507cb43
7</api_key>
  <group>authentication_failed,web,firewall</group>
  <alert_format>json</alert_format>
</integration>
```

Figure 7.1 — Abusel

API Keys

Check out our API docs to learn how to use the API.

Name	Key		Last Used(UTC)	
abusel key	2cc70bfc7f207d91f2cd9d6f547ecb2e5f00a0c89535f904cefe0c9875911302dbd0e99b507cb437	Hide	Never	COPY DELETE

Figure 15 — Threat intelligence / integration oriented lab evidence.

```
    <decoded_as>virustotal-integration-fields</decoded_as>
    <description>VirusTotal: file confirmed MALICIOUS ($(virustotal.positives)
detections)</description>
    <field name="virustotal.positives" negate="yes">^[0-4]$</field>
    <group>virustotal_malicious,gdpr_IV_35.7.d,pci_dss_11.4,</group>
  </rule>

</group>
```

9.4 AbuseIPDB-Based Rules

```
<group name="threat_intel,abuseipdb,">

  <rule id="100110" level="6">
    <decoded_as>abuseipdb-integration-fields</decoded_as>
    <description>AbuseIPDB: IP $(abuseipdb.ip) has low abuse confidence</description>
    <field name="abuseipdb.abuseConfidenceScore" type="pcre2">^([0-9]|[1-3][0-
9])$</field>
    <group>abuseipdb_low,</group>
  </rule>

  <rule id="100111" level="11">
    <decoded_as>abuseipdb-integration-fields</decoded_as>
    <description>AbuseIPDB: IP $(abuseipdb.ip) has moderate abuse confidence (40-
79)</description>
    <field name="abuseipdb.abuseConfidenceScore" type="pcre2">^(4[0-9]|[5-7][0-
9])$</field>
    <group>abuseipdb_moderate,</group>
  </rule>

  <rule id="100112" level="15">
    <decoded_as>abuseipdb-integration-fields</decoded_as>
    <description>AbuseIPDB: IP $(abuseipdb.ip) is HIGH-CONFIDENCE MALICIOUS (score >=
80)</description>
    <field name="abuseipdb.abuseConfidenceScore" type="pcre2">^(8[0-9]|9[0-
9]|100)$</field>
    <group>abuseipdb_malicious,pci_dss_11.4,</group>
  </rule>

</group>
```

Figure 16 — Alert enrichment view used when validating IOC-driven detections.



Figure 10.2 — VirusTotal Lookup Result for EICAR Hash

Screenshot of integrations.log entry or Dashboard alert showing VirusTotal positives count for the EICAR SHA256.

Result: VirusTotal returned 55+ engine detections for the known EICAR signature, satisfying rule 100102 (level 15, Critical) as expected. A subsequent test with a freshly compiled, non-malicious Hello World binary returned 0 detections, correctly firing only informational rule 100100 with no escalation — confirming the absence of false positives on benign content.

10.3 Test Execution — TC-03 / TC-04 (AbuseIPDB)

```
$ curl -s -G https://api.abuseipdb.com/api/v2/check \
    --data-urlencode "ipAddress=185.220.101.45" \
    -d maxAgeInDays=90 \
    -H "Key: $ABUSEIPDB_API_KEY" -H "Accept: application/json" | jq .
```



Figure 17 — Dashboard-style view supporting campaign-level review.

MITRE ATT&CK Coverage (Lab)

Tactic	Technique	ID
Reconnaissance	Active Scanning	T1595
Credential Access	Brute Force	T1110
Defense Evasion	Masquerading	T1036
Persistence	Cron	T1053.003
Lateral Movement	SMB Admin Shares	T1021.002
Collection	Archive via Utility	T1560.001
Exfiltration	Exfil Over C2	T1041
C2	App Layer Protocol	T1071.001

Figure 18 — ATT&CK techniques covered by the Crimson Dawn lab narrative.

10. CISO & Board-Level Brief

10.1 Executive summary

A simulated external group reached a perimeter web host, maintained access with scheduled tasks, moved into an internal Windows workstation, and prepared sensitive files for outbound transfer to a known malicious address. In production the same path would threaten intellectual property, regulatory exposure, and public reputation.

10.2 Attack narrative

- Reconnaissance / delivery — scanning and failed authentication (T1595, T1110).
- Installation — masqueraded payload under /tmp (T1036).
- Persistence — root cron beacon pattern (T1053.003).
- Lateral movement — SMB admin-share style access (T1021.002).
- Collection — archiving of SensitiveFiles (T1560.001).
- C2 / exfiltration — outbound attempt to 192.168.1.200 (T1041, T1071.001).

10.3 Business impact

Targeted data: SensitiveFiles (stand-in for IP or customer material). Potential impact: proprietary leak, notification costs, and brand damage from a public dump narrative.

10.4 Root cause

- Unpatched or weak perimeter service on the web VM.
- Weak segmentation between web tier and internal workstations.
- Limited early detection of masqueraded binaries and new cron jobs.
- No pre-existing block for the C2 indicator until rule 100001.

10.5 Strategic recommendations

- Network segmentation between web tier and workstations.
- Vulnerability management with patch SLAs on internet-facing hosts.
- Process telemetry (Sysmon/EDR) feeding Wazuh for 7z/curl/PsExec behaviours.
- Automated IOC ingest into local rules or CDB lists.
- Quarterly purple-team replay of this kill chain.

11. Lab Challenge Questions

Q1 — Additional Windows persistence

With admin rights on Windows: new service (T1543.003), Registry Run key (T1547.001), or scheduled task (T1053.005) would keep access after reboot.

Q2 — Proactive Vulnerability Detection

Continuous Vulnerability Detector on the web server would highlight the outdated service before exploitation, removing the initial access path the rest of the chain depends on.

Q3 — Bypassing an IP-based C2 block

Switch to a domain that resolves to a new IP, use CDN fronting, or abuse a legitimate cloud service. Pair IP rules with domain/DNS and certificate-based detections.

Q4 — Business justification

Enforcing segmentation between the web tier and internal workstations reduces the chance that one perimeter compromise becomes a full data-theft incident, lowering expected loss from IP leakage and breach-notification costs.

12. Conclusion

Operation Crimson Dawn was reconstructed as a full kill chain inside the Wazuh lab: perimeter pressure, foothold and cron persistence, lateral movement to Windows, data staging, and C2-oriented exfiltration. Custom rule 100001 and Vulnerability Detection close the loop from detection engineering to prioritisation. The executive brief frames the same facts as business risk and durable controls.

— End of Report —